

CYBER-PHYSICAL SYSTEMS & IMD EXPLOITATION

Medical Telemetry, Kinetic Threats & Implant Defense.
Enterprise 50-Page Complete Edition.

Disusun Oleh: **Rizki Angga Pratama**
L2 SOC Analyst

HAK CIPTA & DISCLAIMER

Cyber-Physical Systems: Implantable Medical Device (IMD) Exploitation
Edisi Enterprise (50 Halaman Arsitektural)

Disusun oleh: Rizki Angga Pratama, S. Kom, C. Pro

Dokumen ini ditujukan secara eksklusif bagi Arsitek Keamanan Tertanam (Embedded Security Architects), Insinyur Biomedis, dan Tim Forensik Siber Kritis (ICS/CPS) yang bertugas melindungi kehidupan manusia dari eksploitasi perangkat medis jaringan (IoMT).

> **Peringatan Lingkungan Analisis & Bahaya Kinetik:**
> Teknik intersepsi frekuensi radio (SDR) dan dekompilasi firmware yang dibahas di dalam buku ini ditujukan murni untuk memperkuat pertahanan arsitektur alat medis. Menransmisikan *Payload* Radio (Replay Attack) ke perangkat medis implan pada subjek manusia hidup adalah tindakan Kriminal (Percobaan Pembunuhan). Pengujian harus dilakukan 100% pada *Dummy* atau perangkat laboratorium di dalam Sangkar Faraday.

Filosofi Desain:
Buku ini diwarnai dengan tema *Pulse Crimson & Surgical Steel*. Estetika ini merepresentasikan pendaran elektrokardiogram (EKG) berpadu dengan dinginnya baja instrumen bedah mikrokontroler titanium.

© 2026 Hak cipta dilindungi undang-undang. Panduan Pertahanan Alat Kesehatan Nasional.

KATA PENGANTAR

Selama beberapa dekade, keamanan siber hanya berurusan dengan pencurian data—angka di basis data atau dokumen rahasia. Namun, ketika jaringan silikon berkonvergensi dengan tubuh biologis manusia, peretas tidak lagi hanya mencuri uang; mereka memiliki kemampuan jarak jauh untuk menghentikan detak jantung.

Inilah ranah **Cyber-Physical Systems (CPS)**, khususnya Implantable Medical Devices (IMD). Jutaan pasien di seluruh dunia hidup bergantung pada Alat Pacu Jantung (Pacemakers), *Implantable Cardioverter Defibrillators* (ICDs), dan Pompa Insulin nirkabel yang tertanam di dada dan perut mereka. Demi kenyamanan dokter saat mengecek log medis tanpa pembedahan ulang, produsen menyematkan modul Telemetri Nirkabel (RF/Bluetooth) ke dalam organ manusia.

Buku **"Cyber-Physical Systems: IMD Exploitation"** ini adalah eksplorasi teknis ke jantung ancaman tersebut. Kita akan membedah bagaimana protokol komunikasi tertutup (Proprietary) diretas menggunakan *Software Defined Radio* (SDR), menganalisis ancaman *Sleep Denial* yang menguras baterai bedah, serta membangun arsitektur pertahanan otentikasi *Out-of-Band* akustik untuk generasi implan berikutnya. Ini bukan sekadar tentang melindungi sistem; ini tentang mempertahankan hidup.

— Rizki Angga Pratama

DAFTAR ISI (1/2)

BAGIAN I: EKOSISTEM CYBER-PHYSICAL SYSTEMS (IMD)

Bab 1.1 Konvergensi Biologi dan Internet of Medical Things 7
Bab 1.2 Arsitektur Alat Pacu Jantung (Pacemaker) & ICD 8
Bab 1.3 Anatomi Pompa Insulin Nirkabel & CGM Loop 9
Bab 1.4 Topologi Body Area Network (BAN) & Gateway 10
Bab 1.5 Kerentanan Inheren (Security by Obscurity) 11

BAGIAN II: RF TELEMETRY & SDR EXPLOITATION

Bab 2.1 Medical Implant Communication Service (MICS) Band 13
Bab 2.2 Eavesdropping Telemetri dengan Software Defined Radio 14
Bab 2.3 Dekode Modulasi FSK & OOK pada Komunikasi Medis 15
Bab 2.4 Man-in-the-Middle (MitM) & Replay Attacks 16
Bab 2.5 Eksploitasi BLE (Bluetooth Low Energy) pada Implan Modern 17

BAGIAN III: KINETIC ATTACKS (ANCAMAN TERHADAP NYAWA)

Bab 3.1 Battery Depletion Attack (Sleep Denial) 19
Bab 3.2 Malicious Dosage Alteration (Overdosis Insulin Jarak Jauh) 20
Bab 3.3 Pacing Overdrive & Syok Defibrilator Ilegal 21
Bab 3.4 Serangan Downgrade Firmware Kinetik 22
Bab 3.5 Menyalahgunakan Fitur Akses Kedaruratan (Emergency Bypass) 23

DAFTAR ISI (2/2)

BAGIAN IV: HARDWARE & FIRMWARE FORENSICS

Bab 4.1 Ekstraksi Mikrokontroler dari Cangkang Titanium Medis 25

Bab 4.2 Audit Port JTAG/UART pada PCB Programmer Alat Medis 26

Bab 4.3 Rekayasa Balik (Reverse Engineering) Protokol Berpemilik 27

Bab 4.4 Static Analysis Biner Medis menggunakan Ghidra 28

Bab 4.5 Pencurian Kunci Enkripsi Statis Tersandi (Hardcoded Keys) 29

BAGIAN V: ARSITEKTUR PERTAHANAN KRITIS (IMD DEFENSE)

Bab 5.1 Implementasi Rolling Codes & Anti-Replay Tokens 31

Bab 5.2 Out-of-Band (OOB) Authentication via Piezoelektrik Akustik 32

Bab 5.3 IDS Berbasis Anomali Denyut Nadi Tertanam (Embedded) 33

Bab 5.4 Kriptografi Ringan Preservasi Baterai (Lightweight Crypto) 34

Bab 5.5 Fail-Safe States & Pembatas Dosis Mekanis 35

BAGIAN VI & VII: HOSPITAL IOT & FUTURE REGULATORY

Bab 6.1 - 6.5 HL7 Vulnerabilities, Implant Programmer & Ransomware 37-41

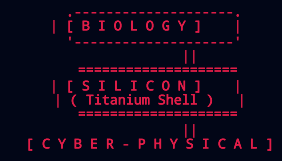
Bab 7.1 - 7.5 FDA Framework, BCI (Neuralink) & Quantum Threats 43-47

REFERENSI & GLOSARIUM

Referensi Jurnal & Standar (FDA/NIST) 48

Glosarium Siber Biomedis 49

Back Cover (The Bio-Cyber Architect) 50



BAGIAN I

Ekosistem Cyber-Physical Systems (Anatomi Implantable Medical Devices)

BAB 1: KONVERGENSI BIOLOGI & MESIN

1.1 Konvergensi Biologi dan Internet of Medical Things

Internet of Medical Things (IoMT) telah mengubah tubuh manusia menjadi simpul (Node) jaringan aktif. Sistem Siber-Fisik (Cyber-Physical Systems/CPS) di ranah biomedis bukan lagi sekadar alat pemantau kebugaran di pergelangan tangan, melainkan mesin penunjang kehidupan yang ditanamkan melalui operasi bedah ke dalam dada, rongga perut, atau korteks otak pasien.

Secara esensial, Implantable Medical Devices (IMD) adalah mikrokontroler tertanam yang dilengkapi dengan sensor elektroda, paket baterai padat berumur 7-10 tahun, dan pemancar nirkabel. Batas pertahanan siber tradisional (Firewall, IDS) tidak dapat diterapkan di sini karena kendala daya yang ekstrem. Jika sebuah implan menghabiskan tenaga komputasi untuk menjalankan rutinitas enkripsi SSL berat, baterainya akan terkuras dalam seminggu, mengharuskan pasien menjalani operasi bedah terbuka yang mengancam nyawa untuk mengganti implan.

1.2 Arsitektur Alat Pacu Jantung & ICD

Alat Pacu Jantung (Pacemakers) dan *Implantable Cardioverter Defibrillators* (ICDs) adalah puncak rekayasa CPS kinetik. Pacemaker memantau aritmia jantung dan mengirimkan sinyal listrik tegangan rendah (Pacing) untuk mengatur detak jantung. ICD melangkah lebih jauh: jika mendeteksi fibrilasi ventrikel yang mematikan, ICD akan melepaskan kejutan listrik tegangan tinggi (hingga 800 Volt) untuk memulai ulang irama jantung.

Kedua alat ini dihubungkan secara nirkabel agar kardiolog dapat mengubah ambang batas (Threshold) perawatan atau mengunduh log EKG tanpa menyentuh pasien. Namun, antarmuka nirkabel ini adalah Gerbang Kematian (Kill Gate). Arsitektur lama sering tidak memiliki otentikasi apa pun: jika Anda memiliki alat pemrogram (Programmer Device) dengan frekuensi yang tepat, implan di dada pasien akan patuh secara membabi buta pada instruksi apa pun yang diterimanya.

1.3 Anatomi Pompa Insulin Nirkabel & CGM Loop

Sistem tertanam medis untuk penderita diabetes modern terdiri dari **Closed-Loop System**. Sistem ini memiliki tiga komponen siber: *Continuous Glucose Monitor* (CGM) yang menempel di kulit untuk membaca gula darah, Aplikasi Ponsel Pintar / *Controller*, dan Pompa Insulin (Insulin Pump) yang menyuntikkan hormon ke pembuluh darah.

Ketiga entitas ini berbicara menggunakan protokol nirkabel jarak dekat (Bluetooth Low Energy atau RF 868/915 MHz). Jika komunikasi *Telemetry* ini dikompromikan (Spoofing), pompa dapat ditipu untuk percaya bahwa gula darah pasien sedang berada di angka 400 mg/dL (padahal normal), memicu pompa untuk melepaskan dosis fatal insulin maksimum (Bolus) yang akan membunuh pasien melalui Syok Hipoglikemik dalam hitungan menit.

1.4 Topologi Body Area Network (BAN) & Gateway

Tubuh pasien modern membentuk topologinya sendiri yang disebut **Wireless Body Area Network (WBAN)**. Implan pacu jantung berkomunikasi dengan perangkat eksternal *Gateway* (seperti kotak stasiun pangkalan / Base Station di meja samping tempat tidur pasien).

Gateway ini menjembatani jaringan RF MICS intra-tubuh dengan jaringan TCP/IP Internet luar (seluler atau Wi-Fi rumah), lalu mengirim data ke Server Awan (Cloud) Rumah Sakit (seperti jaringan Medtronic CareLink). *Gateway* rumahan ini sering kali berjalan menggunakan sistem operasi Linux usang yang penuh celah keamanan. Peretas bisa mengeksploitasi *Gateway* ini dari internet publik, mengubahnya menjadi proksi senjata (*Pivot Point*) untuk mengirimkan paket RF mematikan langsung ke implan saat pasien sedang tidur.

1.5 Kerentanan Inheren (Security by Obscurity)

Hingga dekade terakhir, industri produsen alat medis mengandalkan paradigma **Security by Obscurity** (Keamanan Melalui Kerahasiaan). Mereka berasumsi bahwa karena alat mereka menggunakan protokol Radio Frekuensi (RF) kustom yang tidak didokumentasikan di publik, dan alat Pemrogram (*Programmer Box*) seharga $20,000 sangat langka di pasaran, peretas tidak akan memiliki akses untuk menemukan kerentanan.

Revolusi perangkat keras murah (Raspberry Pi, Software Defined Radio senilai $150) telah menghancurkan asumsi tersebut. Peneliti keamanan dapat dengan mudah menyadap udara, merekam gelombang, dan merekayasa balik (Reverse Engineer) protokol RF berpemilik ini di garasi mereka, memaparkan fakta mengerikan bahwa banyak implan kelas 3 (Life-Sustaining) mentransmisikan data dalam teks terang murni tanpa satupun perlindungan Kriptografi (No Encryption).



BAGIAN II

RF Telemetry & SDR Exploitation
(Menyadap Denyut Udara)

BAB 2: SENJATA NIRKABEL BIOMEDIS

2.1 Medical Implant Communication Service (MICS)

Agar Implan dapat memancarkan data menembus jaringan otot, tulang, dan lemak manusia tanpa memasak (memanaskan) organ dalam, perangkat medis jarak jauh menggunakan pita frekuensi **Medical Implant Communication Service (MICS)** yang dikhususkan pada pita **402 - 405 MHz**.

Pita frekuensi MICS memiliki daya pancar maksimal yang sangat rendah (umumnya di bawah 25 mikrowatt/μW). Daya rendah ini membatasi jangkauan komunikasi efektif (Normal) hanya sekitar 2 hingga 5 meter. Dokter harus mendekatkan Tongkat Pemrogram (*Wand*) ke dada pasien. Namun, dengan menggunakan Antena Yagi gain tinggi dan penguat sinyal (LNA), penyerang di parkiran luar rumah sakit dapat menangkap atau menyuntikkan (Transmit) paket MICS ke implan pasien dari jarak puluhan meter.

2.2 Eavesdropping Telemetri dengan SDR

Pemburu ancaman RF menggunakan alat **Software Defined Radio (SDR)** seperti *HackRF One* atau *USRP*. SDR tidak bergantung pada cip perangkat keras fisik untuk mendecode gelombang; ia menarik gelombang elektromagnetik mentah (I/Q Data) langsung ke komputer, membiarkan perangkat lunak (GNU Radio) mengolahnya.

```
        # Contoh pipeline konseptual SDR Eavesdropping (GNU Radio) [RTL-SDR Source: 403 MHz] -->
[Low Pass Filter] --> [Quadrature Demod] | [File Sink: pacemaker_dump.iq] <-- [Clock Recovery] <--
----+
```

Dengan alat ini, penyerang dapat memantau udara terbuka saat seorang pasien diperiksa oleh dokternya (Eavesdropping). Mereka merekam rentetan (Burst) sinyal radio. Karena kurangnya lapisan enkripsi Transport (Tidak ada SSL/TLS di MICS jadul), penyerang dapat membaca identitas implan, nomor seri, nama pasien, dan log riwayat EKG jantung secara langsung (Cleartext).

2.3 Dekode Modulasi FSK & OOK pada Medis

Bagaimana gelombang radio diubah menjadi data digital 0 dan 1? Implan medis lawas mengandalkan skema modulasi hemat daya: **OOK (On-Off Keying)** dan **FSK (Frequency Shift Keying)**.

Dalam *On-Off Keying*, memancarkan daya RF berarti 1, dan mematikan RF berarti 0. Ini sangat menghemat baterai implan (karena pemancar dimatikan 50% dari waktu). Analis menggunakan perangkat lunak (Universal Radio Hacker / URH) untuk secara visual menyorot pita rekaman radio. Mereka menerapkan algoritma deteksi amplop (Envelope Detection) pada grafik gelombang untuk secara instan dan otomatis mengonversi gunung gelombang radio kembali menjadi struktur data heksadesimal mentah (Raw Hex Dump).

2.4 Man-in-the-Middle (MitM) & Replay Attacks

Kerentanan terbesar telemetri tak terenkripsi adalah **Replay Attack (Serangan Ulangan)**. Meskipun penyerang mungkin tidak tahu bagaimana cara menulis perintah (Command) dari nol, mereka tidak perlu tahu. Mereka cukup merekam *Playback* perintah sah yang dikirim oleh dokter.

Misalnya, saat dokter menekan tombol "Beri Bolus Insulin 5 Unit", SDR penyerang merekam gelombang tersebut menjadi berkas audio digital. Saat pasien sedang tidur sendirian, penyerang memutar (Transmit/Replay) ulang berkas rekaman radio tersebut menggunakan *HackRF*. Karena pompa insulin bodoh tidak memiliki *Timestamp* (Nonce) anti-Replay, ia akan menerima gelombang tersebut sebagai perintah sah, menyuntikkan 5 unit. Penyerang mengulang transmisi ini (Script Loop) sebanyak 10 kali dalam satu detik, membunuh target via overdosis hormon.

2.5 Eksploitasi BLE pada Implan Modern

Implan medis modern (pasca-2020) mulai meninggalkan MICS band dan mengadopsi **Bluetooth Low Energy (BLE - 2.4 GHz)**. Ini memungkinkan pasien mengecek status implan mereka (Gula darah / Detak Jantung) langsung dari Smartphone Android tanpa perlu alat *Wand* berpemilik (Proprietary).

Kenyamanan ini membuka celah masif. Serangan kini bergeser dari ranah perangkat keras radio (SDR) ke peretasan Aplikasi Seluler (APK). Jika ponsel Android pasien berhasil diinfeksi oleh *Malware* (misal: diunduh dari luar PlayStore), *Malware* tersebut mewarisi kunci otentikasi (Pairing Keys) BLE ke Implan. *Malware* ponsel (Trojan) kini dapat secara lateral (Lateral Movement) mengendalikan alat medis di dalam dada pengguna tanpa memancarkan sinyal RF eksternal apa pun (Serangan dari Saku Pasien Sendiri).



BAGIAN III

Kinetic Attacks & Ancaman Nyawa (Cyber-Physical Lethality)

BAB 3: SERANGAN MEMATIKAN (KINETIK)

3.1 Battery Depletion Attack (Sleep Denial)

Baterai pada Alat Pacu Jantung dirancang untuk bertahan 10 tahun (Ditanam di bawah kulit). Untuk menghemat daya, sirkuit pemancar radio implan dalam kondisi tidur pulas (Deep Sleep) 99.9% dari waktu. Ia hanya menggunakan sirkuit pemantau gelombang (Wake-up Circuit) pasif daya-nano untuk menunggu interupsi.

Penyerang menggunakan **Sleep Denial Attack (Serangan Pengurasan Baterai)**. Menggunakan pemancar RF jarak jauh otomatis, peretas mengirimkan ribuan permintaan jabat tangan (Pings/Wake-Up Calls) yang palsu atau tidak lengkap setiap menit. Implan secara refleks akan membangunkan unit CPU dan Radiologinya ke status Daya Penuh (High-Power State) untuk merespons ping radio tersebut, menguras kapasitas litium baterai 10 tahunnya habis dalam waktu kurang dari 3 minggu, memaksa bedah darurat.

3.2 Malicious Dosage Alteration

Serangan pada pompa cairan (Insulin/Obat Nyeri Epidural) diklasifikasikan sebagai **Malicious Dosage Alteration**. Berbeda dengan pacemaker yang mengatur impuls kelistrikan, pompa obat mengontrol pengiriman volume farmasi fisik mikro-liter menggunakan aktuator bermotor.

Peretas yang berhasil menembus otentikasi nirkabel (Wireless Authentication Bypass) tidak hanya bisa memicu *Bolus* maksimal, tetapi mengubah parameter Konfigurasi Tetesan Basal Dasar (Basal Rate Profile). Dengan secara diam-diam mematikan (Set to Zero) tetesan obat jantung harian di tabel memori pompa, gejala pasien akan memburuk perlahan selama berminggu-minggu tanpa jejak peretasan eksplisit (Stealth Murder), meniru kematian akibat kegagalan organ alami.

3.3 Pacing Overdrive & Syok Ilegal

Pada pasien dengan alat *Implantable Cardioverter Defibrillator (ICD)*, alat ini berfungsi sebagai penjaga. Jika mendeteksi Henti Jantung (Cardiac Arrest), ICD melepaskan satu kali tembakan kejut 800 Volt untuk mereset fungsi bilik jantung (T-Shock).

Jika dikompromikan, peretas dapat mengirimkan perintah telemetri darurat: **Induce Fibrillation (Pacing Overdrive)**. Mode kalibrasi diagnostik klinis (yang seharusnya digunakan dokter di Rumah Sakit) dieksploitasi untuk memerintahkan alat mempercepat detak jantung (Tachycardia Buatan). Lebih brutal lagi, peretas dapat memerintahkan ICD untuk melepaskan seluruh simpanan kapasitor 800 Volt-nya langsung ke otot jantung pasien saat pasien sedang sehat (Inappropriate Shock), melumpuhkan korban seketika dengan nyeri hebat yang dapat memicu serangan jantung fatal sekunder.

3.4 Serangan Downgrade Firmware Kinetik

Pabrikan medis modern telah menambal lubang keamanan perangkat lawas dengan meluncurkan Pembaruan *Firmware Over-The-Air (OTA)* nirkabel yang mengimplementasikan Tanda Tangan Digital (Cryptographic Signatures).

Namun, jika pabrikan tidak menerapkan pemeriksaan *Anti-Rollback* (Sekering Kriptografis), peretas (Red Team) akan melancarkan **Firmware Downgrade Attack**. Mereka mengirimkan perintah kepada implan untuk menimpa sistem barunya dan kembali memuat versi *Firmware* v1.0 yang sudah usang (dan memiliki kerentanan *Replay Attack*). Setelah implan turun kasta (Downgraded), seluruh eksploitasi lawas yang berbahaya dapat digunakan kembali untuk membunuh.

3.5 Fitur Akses Kedaruratan (Emergency Bypass)

Insinyur Medis menghadapi dilema moral: **Emergency Access Contradiction**. Bagaimana jika seorang pasien dilarikan ke Instalasi Gawat Darurat (UGD) di luar negeri dalam keadaan koma? Dokter asing tidak memiliki kunci Kata Sandi (Credentials) nirkabel untuk masuk ke pompa insulin pasien.

Karenanya, banyak implan mengimplementasikan fitur **Emergency Bypass (Master Key / Magnet Mode)**. Menempelkan magnet medis kuat (Neodymium) di dada pasien, atau menggunakan Master PIN (Hardcoded 000000), akan membuka antarmuka pabrik. Peretas fisik yang berdekatan dengan pasien di kereta komuter dapat memicu saklar geluh (Reed Switch) implan secara magnetis dari luar baju, menidurkan keamanan kriptografinya, lalu mengambil alih kendali (Close-Proximity Override).



BAGIAN IV

Hardware & Firmware Forensics (Membongkar Otak Silikon)

BAB 4: FORENSIK CIP PERANGKAT KERAS

4.1 Ekstraksi Mikrokontroler (Titanium Shell)

Peneliti Keamanan (White Hats) membeli implan jantung (bekas atau di eksplan) dari pasar sekunder medis eBay untuk meretas (*Reverse Engineer*) logikanya. Tantangan pertama adalah Perangkat Keras.

Alat pacu jantung disegel secara hermetis di dalam Cangkang Titanium laser (Titanium Laser-Welded Can) untuk melindunginya dari cairan tubuh (Darah/Asam). Untuk menembusnya tanpa merusak sirkuit memori (*Logic Board*) halus di dalamnya, peneliti menggunakan pemotongan mikro mekanis presisi (Dremel Cutt-off wheel) untuk membuka jahitan Titanium, membongkar modul baterai litium-yodium (Lithium-Iodine), memaparkan Mikrokontroler Kustom (Medical SoC) yang tidak terdokumentasi (Undocumented Silicon) yang menjalankan otak perangkat tersebut.

4.2 Audit Port JTAG/UART pada Programmer

Meretas dari implannya (dalam dada) itu sulit. Meretas dari Kotak Konsol Dokter (**Device Programmer Box**) jauh lebih mudah. *Programmer Box* (seperti perangkat yang berjalan di OS Windows XP/7 usang) adalah dewa (Master Control) bagi implan.

Peneliti membongkar Kotak Pemrogram (Programmer) dan mencari pin antarmuka keras **UART (Universal Asynchronous Receiver-Transmitter) atau JTAG** yang dibiarkan terbuka oleh tim rekayasa pabrikan di papan sirkuit hijau (PCB). Dengan mencolokkan penganalisis logika (*Logic Analyzer* / FTDI), peneliti mencegat aliran komunikasi serial dan menghentikan (Halt) CPU perangkat, membiarkan peneliti mengekstraksi (*Dump*) blok penyimpanan memori EEPROM (Firmware) keluar dari mesin tertutup tersebut untuk dianalisa di komputer forensik.

4.3 Reverse Engineering Protokol Berpemilik

Produsen IMD sering kali tidak menggunakan protokol Standar (TCP/IP), melainkan tumpukan paket Radio RF *Kustom Proprietary* murni. Untuk memahaminya, pemburu ancaman siber melakukan analisa Biner Buta (Blind Protocol Analysis).

Berdasarkan tangkapan rekaman *SDR (Hex Dumps)* dan perbandingan memori yang ditarik dari kotak pemrogram (Memory Dumps), analis menggunakan algoritma korelasional untuk menebak susunan Format Bingkai Paket (Frame Structure). Mereka mengidentifikasi *Byte Preambul, Sync Word, ID Pasien (3 Bytes), Tipe Perintah (1 Byte Opcodes)*, dan blok pemeriksa kesalahan (CRC). Proses pembedahan algoritma matematika buram (Obfuscation) ini memakan waktu berbulan-bulan, namun hasil akhirnya adalah skrip *Python* yang mampu menulis-ulang perintah komunikasi implan yang sempurna.

4.4 Static Analysis Biner Medis (Ghidra)

Setelah *Firmware Biner Mentah* (Misal: berformat arsitektur MSP430 atau ARM Cortex-M) berhasil diekstraksi dari chip memori implan, biner mentah tersebut dilemparkan (Import) ke alat Dekompilator canggih standar NSA: **Ghidra** atau **IDA Pro**.

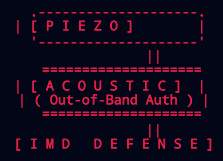
Alat ini mengubah (Disassemble) blok hex kembali menjadi instruksi perakitan (Assembly) dan secara ajaib mengembalikannya menjadi semu C-Code (Decompiled Pseudocode). Analis forensik menyisir baris fungsi-fungsi tersebut (Static Analysis) untuk memburu cacat logika klasik: *Buffer Overflows* pada rutinitas penanganan paket Radio Masuk (Incoming RF Parsers), Logika Pintasan (Bypass Logic), atau kelemahan fungsi (RNG/Random Number Generator) yang dapat dieksploitasi lewat jaringan udara nirkabel.

4.5 Pencurian Kunci Enkripsi (Hardcoded Keys)

Ketika produsen mencoba (akhirnya) menerapkan enkripsi kriptografi AES pada komunikasi nirkabel alat pacu jantung, mereka sering jatuh pada dosa rekayasa perangkat lunak terbesar: **Hardcoded Global Keys (Kunci Rahasia Tertanam)**.

```
        /* Pseudocode hasil dekode Firmware Medis di Ghidra */ void authenticate_rf_session(byte*
incoming_packet) { const byte GLOBAL_AES_KEY[] = {0xDE, 0xAD, 0xBE, 0xEF, 0x12, 0x34}; // Semua
500,000 unit implan di seluruh dunia menggunakan KUNCI YANG SAMA! aes_decrypt(incoming_packet,
GLOBAL_AES_KEY); }
```

Peneliti menggunakan *Ghidra* untuk menemukan urutan *Key* Statis ini. Karena kunci ini tidak unik (Global Symmetric Key), peretas yang mengekstrak Kunci Rahasia tersebut dari satu alat bekas dari eBay secara harfiah telah mengantongi Kunci Master Universal (Skeleton Key) untuk meretas, mengendalikan, dan membunuh ratusan ribu pasien penderita jantung pengguna merek implan yang sama di seluruh belahan dunia.



BAGIAN V

Arsitektur Pertahanan Kritis (Membangun Implan Kebal Retas)

BAB 5: ZIRAH SIBER MEDIS

5.1 Implementasi Rolling Codes & Anti-Replay Tokens

Mempertahankan Implan dari *Replay Attacks (Serangan Ulangan)* menuntut arsitektur Kriptografi Dinamis. Implan medis tidak terhubung ke jaringan NTP Internet, sehingga sinkronisasi waktu murni (Timestamps) tidak akurat. Solusinya adalah **Rolling Codes (Kode Berputar / Counters)** atau Otentikasi Berbasis Nonce (Tantangan).

Setiap kali Alat Pemrogram Dokter (Programmer) hendak mengirim dosis, ia harus terlebih dahulu mengirimkan *Ping* (Wake) kepada Implan. Implan membangkitkan Angka Acak Sekali Pakai (Cryptographic Nonce) dan mengirimkannya kembali ke udara. Tongkat dokter kemudian mengenkripsi/Tandatangani perintah Dosis Kinetik digabungkan dengan (Nonce) tersebut (Challenge-Response). Karena *Nonce* itu membusuk (Expired) usai satu kali transmisi, rekaman SDR yang dicuri oleh peretas menjadi sampah matematik (Invalid Signature) saat dicoba diputar-ulang di malam hari.

5.2 Out-of-Band (OOB) Authentication via Piezo

Jika jaringan nirkabel (RF/BLE) tidak bisa dipercaya dari ancaman jarak jauh (Remote Attacks), Arsitek Keamanan Biomedis mengalihkan validasi persetujuan ke Jalur Fisik Sekunder: **Out-of-Band (OOB) Authentication**.

Implan dilengkapi sensor Piezoelektrik (Audio/Getaran) atau Sensor Fotodioda (Cahaya Optik menembus kulit). Ketika dokter mengubah batas ritme detak jantung via Radio Nirkabel, Implan akan Menolak instruksi itu (Deny) *KECUALI* jika dokter secara bersamaan menempelkan Stetoskop Akustik Elektrik di dada pasien yang mengirimkan Kode PIN ketukan suara (Acoustic PIN), atau mem-*flash* kode morse Lampu LED ke arah tulang rusuk. Akses hanya diberikan jika penyerang hadir secara Fisik (Proximity Bound) di sebelah kulit dada pasien.

5.3 IDS Berbasis Anomali Denyut Nadi Tertanam

Sistem Deteksi Intrusi (IDS) tradisional terlalu berat untuk Micro-CPU Medis (seukuran uang logam). Akademisi siber mengembangkan **Biometric/Physiological Anomaly IDS**.

IDS ini tidak memindai paket jaringan TCP (seperti di server web). IDS Implan secara lokal (Embedded) membaca sinyal Biologis sensor jantung pasien secara *Real-Time*. Jika implan menerima Perintah (Command Paket Radio Sah) untuk menembakkan Syok 800 Volt, tetapi Sensor EKG mesin (Biometrik Fisik Hati) menunjukkan ritme sinus normal (Pasien sedang rileks/Sehat), CPU Implan akan membangkang instruksi radio nirkabel tersebut (Command Veto), menyimpulkan transmisi itu sebagai operasi *Malicious Spoofing* jarak jauh.

5.4 Kriptografi Ringan Preservasi Baterai

Menerapkan algoritma enkripsi AES-256 (Tingkat Bank) pada CPU Implan (MIPS/MSP430 16-bit 2MHz) akan memakan ratusan mili-Watt daya dan menguras baterai bedah. Industri beralih pada **Lightweight Cryptography (LWC)**.

Alih-alih algoritma berat komputasi (AES), Konsorsium NIST menstandardisasi Cipher Ringan seperti **ASCON** atau **PRESENT**. Algoritma Kripto Biner Mikro ini dioptimalkan murni pada level gerbang logika Perangkat Keras (ASIC Silicon Gates), hanya memakan fraksi (sepersepuluh) siklus jam mikrodetik CPU dan arus Nano-Ampere. LWC memungkinkan komunikasi Enkripsi Teks Rahasia penuh (Encrypted Telemetry) sambil mempertahankan umur hidup paket Baterai Pasien hingga 12 Tahun penuh (Low-Energy Security).

5.5 Fail-Safe States & Pembatas Dosis Mekanis

Sebagai lapisan terakhir (Defense in Depth), keamanan tidak boleh disandarkan hanya pada peranti lunak (Software). Jika penyerang mengeksploitasi Buffer Overflow (*RCE*) dan mengambil alih hak akses Penuh (*Root*) Micro-OS di dalam Pompa Insulin, mereka akan mencoba memerintahkan Motor Aktuator memompa seluruh 300 Unit tabung cairan ke aliran darah pasien.

Desain Pertahanan Mutlak harus memuat **Mechanical Hardware Fail-Safes** (Pembatas Volume Fisik). Aktuator dosis disekat secara mekanis keras (*Hard-Wired Watchdog Timers*) atau memiliki rongga fisik reservoir batas dosis yang tidak dapat dilangkahi oleh instruksi perangkat lunak (Software Veto) apa pun. Bahkan jika OS diretas dan memerintahkan "Beri Bolus Tembus Batas", sekering mekanik keras di dalam pompa tersebut akan terbakar dan macet, melindungi nyawa pasien dari pembunuhan digital jarak jauh.



BAGIAN VI

Hospital Infrastructure & IoT (Serangan Terhadap Rumah Sakit)

BAB 6: INSIDEN KRITIS PERAWATAN MEDIS

6.1 Vektor Serangan Protokol Medis HL7 & DICOM

Sistem Siber Fisik Medis tidak beroperasi sendirian. Di Rumah Sakit, semua mesin diagnostik dan rekaman elektronik terhubung menggunakan protokol usang: **HL7 (Health Level Seven)** untuk rekaman (Teks) dan **DICOM** untuk Mesin Pemindai Gambar MRI/X-Ray.

Protokol internal medis ini dikembangkan di tahun 1980-an dengan asumsi *Trusted Network* dan dikirim tanpa Enkripsi (Cleartext TCP). Peretas (Man-in-the-Middle) di jaringan Wi-Fi tamu rumah sakit dapat menyadap paket HL7, atau lebih buruk lagi, menyuntikkan Paket Palsu yang secara diam-diam memanipulasi *Metadata* golongan darah pasien di layar operasi Bedah. Pasien dapat meninggal di meja bedah akibat transfusi Darah Otoritatif yang salah (Data Integrity Attack) tanpa ada mesin yang meledak.

6.2 Clinical Network Segmentation

Mesin MRI, Pompa Infus Jaringan (Networked IV Pumps), dan konsol monitor jantung di bangsal Pasien Intensif (ICU) sering kali menjalankan Windows XP atau Windows 7. Alat-alat jutaan Dolar (FDA Certified) ini tidak dapat dipasang Antivirus atau ditambal (Patched) karena Modifikasi OS sedikit saja akan melanggar kepatuhan Izin Klinis pabrikan (Void Warranty).

Solusi pertahanan infrastruktur (SecOps) adalah **Clinical Micro-Segmentation (VLAN/SDN Keras)**. Peralatan Biomedis IoT Kritis disegel dalam Jaringan Logika Virtual terisolasi. *Firewall Core* melarang mesin mesin medis ini berselancar ke internet (Zero Internet Egress) atau berkomunikasi dengan *Workstation* Admin (HRD), mencegah penyebaran (Lateral Movement) *Worm* IT biasa agar tidak pernah menyentuh Mesin Pompa Infus pernafasan ICU.

6.3 Implant Programmer Hacking

Alih-alih bersusah payah menargetkan RF Implan di udara terbuka, APT menyerang mata rantai paling lemah di pusat kendali rumah sakit: **Implant Programmer Tablet**. Mesin Tablet Portabel yang dibawa dokter dari kamar ke kamar (Untuk menyesuaikan dosis pacu jantung pasien).

Peretas menggunakan taktik *Spear Phishing* atau (Infected USB Drop) untuk mengkompromikan tablet pemrogram yang usang tersebut. Setelah *Malware* (*Trojan*) bersarang secara senyap (Persistence) di dalam komputer Programmer Dokter, *Malware* tersebut menunggu (Dormant). Saat alat dihidupkan untuk memeriksa implan pasien, *Malware* secara otomatis membonceng (Piggybacking) koneksi Radio yang dipercaya, menanamkan Firmware (*Downgrade*) Implan beracun tanpa disadari oleh kardiolog yang mengoperasikannya (Man-in-the-Endpoint).

6.4 Wireless Gateway Compromise

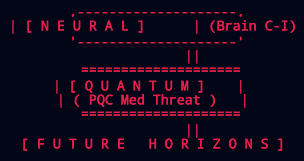
Banyak pasien dibekali Stasiun Pangkalan Nirkabel Pemantau Jarak Jauh (Home Bedside Monitor / Wireless CareLink Gateway) yang dicolokkan ke Wi-Fi rumah mereka. *Gateway* ini mengumpulkan data EKG Jantung semalaman (Lewat Bluetooth) dan mengunggahnya ke server Awan (Cloud AWS Rumah Sakit) pada pagi hari.

Jika Router Wi-Fi rumah pasien menggunakan kata sandi lemah (WEP/WPA yang Retas), peretas komuter lokal membobol jaringan Wi-Fi rumah pasien (Wardriving). Dari sana, peretas membidik port *Telnet* atau Antarmuka Web HTTP tak terenkripsi (Hardcoded Default Credentials) pada kotak Gateway Monitor Implan tersebut. Setelah Gateway dikuasai, penyerang memiliki Proksi Terowongan (Pivot Node) permanen ke dalam bilik kamar tidur pasien untuk melancarkan Eksploitasi Dosis (*Overdose*) kapan saja.

6.5 Ransomware in Healthcare (Pembunuhan Massal Siluman)

Industri Kesehatan Global dilanda epidemi **Ransomware (WannaCry / Ryuk / BlackCat)**. Secara sejarah, kartel Ransomware hanya mengunci (Enkripsi Teks) berkas tagihan keuangan peladen administrasi rumah sakit.

Tetapi dengan terhubungkannya Jaringan IoT Biomedis, Ransomware modern bermutasi melumpuhkan Layanan Kinetik (Denial of Care). Jika Ransomware menginfeksi (Encrypt) Server Sistem Penyedia Resep Farmasi Internal, perawat buta terhadap dosis (*Dosage Lockout*). Jika Monitor Telemetri Jantung (Central Nursing Station) terenkripsi gelap (Blackout), para dokter tidak tahu jika ada salah satu dari puluhan pasien di bangsal yang jantungnya berhenti mendadak. Kematian Pasien sekunder akibat Kelumpuhan Rantai Pasok Diagnostik Siber ini adalah dampak fatalitas tak langsung tertinggi dari eksploitasi rumah sakit abad ini.



BAGIAN VII

Regulatory & Future Horizons
(Evolusi Siber Biomedis & Otak Mesin)

BAB 7: REGULASI & ERA TRANSHUMANISME

7.1 FDA Cybersecurity Framework & Regulasi Hukum

Menanggapi krisis keamanan alat kesehatan yang merenggut banyak korban potensial, Badan Pengawas Obat dan Makanan AS (**FDA / Food and Drug Administration**) merilis Kerangka Regulasi *Premarket & Postmarket Cybersecurity*.

Hukum berubah secara Drastis: FDA sekarang memiliki otoritas Hukum Nasional yang mengikat untuk **Menolak (Reject/Banned) Persetujuan Klinis Jual Alat Medis Baru** HANYA karena pabrikan alat tersebut tidak memiliki rencana tambalan kerentanan siber (Patch Management Plan / CVE Response) pasca-pasar, atau alat gagal membuktikan penerapan Enkripsi data transit. Keamanan Siber (*Cybersecurity*) kini secara literal (Hukum Status) setara dampaknya dengan Uji Klinis Keselamatan Toksisitas Obat Medis.

7.2 Software Bill of Materials (SBOM) for Medical

Produsen Perangkat Implan Kritis sering kali tidak menulis kode dari nol; mereka menggunakan Pustaka Terbuka OS Lapis Bawah (Misalnya Linux Kernel / VxWorks OS, atau Tumpukan Bluetooth Sumber Terbuka/BlueZ) yang dibuat oleh puluhan perusahaan lain (Third-Party Components).

Untuk menembus kebutaan rantai pasok (*Supply Chain Transparency*), Rumah Sakit (CISO) diamanatkan untuk meminta **Software Bill of Materials (SBOM)** dari seluruh Vendor Alat Pacu Jantung dan Mesin Operasi Robotik yang mereka beli. Layaknya Label Kandungan Nutrisi pada kemasan makanan, SBOM Medis memetakan setiap dependensi (*Library Hash*) biner di dalam cip Implan tersebut. Jika kerentanan Global Kritis (Log4j/SweynTooth Bluetooth) meledak, Rumah Sakit bisa segera mengisolasi (VLAN) merk alat medis mana saja yang mengandung pustaka beracun (Vulnerable) tersebut dalam hitungan menit tanpa panik meraba-raba.

7.3 Bio-Hacking & Modifikasi Mandiri Manusia (DIY)

Tidak semua peretas alat medis berniat membunuh. Fenomena sosial yang disebut **Bio-Hacking / #WeAreNotWaiting Movement**, adalah saat penderita Diabetes menolak keterbatasan (Lack of Features) Pompa Insulin berpemilik yang dibatasi regulasi Medis ketat Pemerintah (FDA Pacing).

Kelompok peretas *Bio-Hacker* ini meretas (Reverse-Engineer) sendiri Pompa Insulin Tua di tubuh mereka, membuat aplikasi Lingkaran Tertutup Sumber Terbuka *(Open-Source Artificial Pancreas/OpenAPS)* yang disebarkan via GitHub (Mengontrol sekresi insulin via Raspberry Pi secara Algoritmik otonom penuh). Meskipun canggih dan meningkatkan kualitas hidup secara ekstrem (HBa1C), arsitektur swadaya modifikasi siber Tubuh (Do-It-Yourself Cyber-Biology) ini menimbulkan dilema Regulasi Forensik (Liability) tak terpecahkan di ruang rawat gawat darurat medis hukum.

7.4 Brain-Computer Interfaces (BCI) / Neuralink Exploitation

Batas (Frontier) pamungkas dari keamanan Sistem Siber Fisik bukanlah jantung, melainkan Otak Manusia: **Brain-Computer Interfaces (BCI)** seperti cip Neuralink atau Synchron. Alat implan Neural ditanam menembus Tengkorak (Skull) dan elektrodanya dianyam (Milled) langsung mencengkram jaringan Basal Ganglia Neocortex.

Potensi Peretasannya bersifat Distopia (Mind Hacking). Serangan *Man-in-the-Middle* (Bluetooth/RF) pada Cip Neural BCI Modulasi dapat mencegat Perintah Gerak (Motor Intent Interception). Jika peretas menyusup pada sinyal elektroda penstimulasi dalam Otak (Deep Brain Stimulation - DBS) untuk pasien Parkinson, peretas tersebut secara Kinetik dapat merubah suasana psikologis memori otak, melumpuhkan motorik fisik lengan, atau memicu kejang epilepsi listrik buatan (Induced Grand Mal Seizures) semata-mata dengan modifikasi Payload (*Radio Spoofing*) Biner Siber Murni dari Laptop jarak jauh.

7.5 Quantum Threats to Implant Security (Q-Day Medis)

Seluruh sistem medis terkini (Pacemaker generasi 2025) baru saja beralih menggunakan Enkripsi Asimetris klasik (RSA/Elliptic Curve BLE) untuk pertukaran Kunci Dokter-Pasien yang aman. Kiamat Kuantum (Shor's Algorithm / Quantum Computers) di masa depan mengancam membongkar algoritma tersebut (RSA/ECC Break).

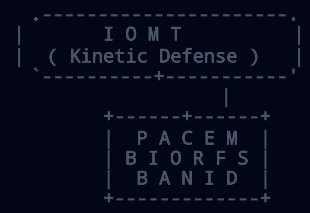
Masalah Kritis pada Alat Implan Medis adalah: **Siklus Hidup (Lifecycle) Implan berada di dalam tubuh manusia selama 12 hingga 15 Tahun**. Implan pacu jantung (*Pacemaker*) yang dioperasi (Ditanamkan) pada tahun ini (2026) akan tetap berada di dalam dinding dada pasien saat fajar *Q-Day* Komputer Kuantum komersial tiba (Est. 2035). Produsen alat biomedis tertanam HARUS mengimplementasikan Kriptografi Pasca-Kuantum (Post-Quantum Cryptography / *Kyber-ML KEM Firmware Ready*) hari ini juga, karena kita tidak bisa memaksa jutaan manusia menjalani Operasi Bedah Pengangkatan Dada massal hanya untuk mengganti Cip Kripto yang usang.

REFERENSI JURNAL & STANDAR KLINIS

- **[1]** FDA (Food and Drug Administration). (2023). *Cybersecurity in Medical Devices: Quality System Considerations and Premarket Submissions*. (Panduan mutlak pengujian siber perangkat biomedis sebelum disetujui pasar).
- **[2]** Halperin, D., et al. (2008). *Pacemakers and Implantable Cardiac Defibrillators: Software Radio Attacks and Zero-Power Defenses*. IEEE Symposium on Security and Privacy. (Paper monumental pertama tentang eksploitasi telemetri pacemaker jarak jauh via SDR).
- **[3]** Lewis, D. (2016). *The OpenAPS Project: Open Source Artificial Pancreas System*. (Gerakan Bio-Hacking swadaya peretasan pompa insulin untuk otomatisasi diabetes mandiri tertutup).
- **[4]** Bonaci, T., Herron, J., & Chizeck, H. J. (2014). *App stores for the brain: Privacy & security in Brain-Computer Interfaces*. IEEE Technology and Society Magazine. (Tinjauan distopia eksploitasi antarmuka Neural/Otak).

GLOSARIUM SIBER BIOMEDIS

TERMINOLOGI	DEFINISI & KONTEKS EKSPLOITASI KINETIK
Battery Depletion Attack (Sleep Denial)	Taktik pembunuhan atau perusakan ketersediaan (Availability) Alat Medis dengan mengirimkan Paket Radio Interupsi Pings (Wake-up) palsu terus menerus. Tujuannya adalah mencegah sirkuit implan tidur (Deep Sleep), membakar cadangan Baterai Bedah Litium 10-Tahun habis dalam hitungan pekan.
MICS (Medical Implant Communication Service)	Pita spektrum Frekuensi Radio khusus (402–405 MHz) jarak pendek ultra-rendah yang dirancang agar komunikasi data dari alat implan dapat menembus keluar batas jaringan tubuh (Daging/Organ) manusia. Target Intersepsi (*Eavesdropping*) bagi peretas yang menggunakan antena penguat SDR.
SDR (Software Defined Radio)	Pisau Swiss-Army (Peretas Udara Nirkabel) Fisika RF. Modul Radio pasif (seperti HackRF One) yang menangkap Spektrum Sinyal Gelombang Analog Mentah (IQ) murni tak terurai untuk dibongkar, dideskripsi-balik modulasi (FSK/OOK), lalu dipancarkan-ulang (Replay) via kode Komputer (Python/GNU Radio) secara siluman jarak jauh.
Telemetry (Medis)	Urat Nadi transfer Data (Komunikasi Nirkabel Bio-Fisik) rahasia Dokter. Jalur *Wireless* tempat log Elektrokardiogram pasien (EKG) diunduh keluar dada pasien, atau tempat Data (Perintah Dosis Kejut/Bolus/Pacing Overdrive Tachycardia) disuntikkan secara kendali kontrol jarak dekat dari Programmer Box di Klinik ke Implan di organ dalam pasien.



The Bio-Cyber Architect

© 2026 All rights reserved.
Enterprise Cyber-Physical Operations Series